

13 Mar 2023

01

US\$ 197M

Euler Finance

"Dez auditorias e nenhuma pegou"

FLASH LOAN + DONATE • CRITICAL

Auditado por 10 firmas diferentes — 100% devolvido após negociação

0 que aconteceu

02

Euler Finance era um dos protocolos de lending mais sofisticados do DeFi, com **10 auditorias** de segurança de firmas renomadas.

O atacante encontrou uma função chamada **donateToReserves** que permitia "doar" tokens para as reservas do protocolo. O problema: **não verificava se o doador continuava solvente.**

Com flash loans, o atacante tomou empréstimos, **doou o colateral para as reservas** (ficando artificialmente insolvente), e então se auto-liquidou com **desconto de liquidação.**

Após negociações, incluindo ameaças de ação legal e comunicação on-chain via mensagens em transações, o atacante **devolveu 100% dos fundos.**

● Contrato Vulnerável

03

INHA VULNERÁVEL

● ● ● SOLIDITY / VULNERABLE

etStorage

```
...y(msg.sender) // Doador pode ficar insolvente! // → se auto-liquida com
desconto }
```

Lição

Toda função que altera colateral ou dívida **precisa verificar solvência** ao final.
Auditorias não são garantia.

Como o ataque funcionou

PASSO 1

Flash loan de 30M DAI



PASSO 2

Deposita 20M DAI no Euler → recebe eDAI



PASSO 3

Toma empréstimo de 195M eDAI (10x alavancado)



PASSO 4

Chama `donateToReserves(100M)`

Colateral cai → fica artificialmente insolvente



PASSO 5

Contrato 2 `liquida Contrato 1`

Recebe colateral com desconto de liquidação



RESULTADO

Lucro: US\$197M

Devolveu 100% após negociação

Verifique na Blockchain

Transação do Ataque

etherscan.io/tx/0xc310a0...111d

Contrato Euler

etherscan.io/address/0x2718...25d3

SMARTCONTRACT ENGINEER

Solidity

Lucas Bispo de Oliv

SMARTCONTRACT

Solidity

Solidity de fo

